



SPD — Sistema de Pagamento Digital

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO E PRIVACIDADE DE DADOS FINANCEIROS

Documento: PSI-SPD-001
Versão: 1.0
Classificação: USO INTERNO
Elaborado por: Gustavo Henrique da Silva Kubiack, Maria Eduarda Nichelle Ferreira, Rafael Francisco Gonçalves Serrano
Data de Elaboração: Junho de 2026
Aprovado por: Diretoria de TI e Compliance
Data de Aprovação: 12/06/2026
Vigência: 12/06/2026 a 12/06/2027

DISTRIBUIÇÃO RESTRITA

SUMÁRIO

SUMÁRIO.....	1
LISTA DE FIGURAS.....	2
LISTA DE TABELAS.....	3
LISTA DE ANEXOS.....	3
LISTA DE SIGLAS E ABREVIATURAS.....	5
1. OBJETIVO.....	7
2. DESCRIÇÃO DO CENÁRIO.....	7
3. ESCOPO.....	9
4. REFERÊNCIAS NORMATIVAS.....	9
5. TERMOS E DEFINIÇÕES.....	11
6. GESTÃO DE RISCOS.....	12
6.1 Critérios de Aceitação e Tratamento de Riscos.....	12
7. PROCEDIMENTOS E POLÍTICAS ESPECÍFICAS.....	14
7.1 Controle de Acesso com Autenticação Multifator (MFA).....	15
7.2 Armazenamento Seguro e Criptografia de Dados Financeiros.....	16
7.3 Descarte Seguro de Logs e Dados Sensíveis.....	17
7.4 Política de Escolha e Troca de Senhas (Alta Criticidade).....	18
7.5 Uso Controlado de Redes Sociais por Funcionários.....	19
7.6 Prevenção e Tratamento de Fraudes Financeiras.....	20
7.7 Gestão de Incidentes, Plano de Contingência e Continuidade.....	21
7.8 Governança da Cadeia de Suprimentos e Gestão de Fornecedores Financeiros.....	22
7.9 Privacidade e Proteção de Dados Pessoais (LGPD).....	23
8. PENALIDADE POR VIOLAÇÃO.....	23
9. DIVULGAÇÃO, CONSCIENTIZAÇÃO E CIÊNCIA.....	24
10. APROVAÇÃO, VIGÊNCIA E REVISÃO.....	26
ANEXO A - Termo de Ciência e Responsabilidade.....	27
ANEXO B - Plano de Ação e Implementação.....	28
Evidências necessárias para auditoria.....	28
ANEXO C - Diretrizes Complementares de Privacidade (LGPD / ISO 27701).....	30
C.1 Papéis e responsabilidades.....	30
C.2 Principais fluxos de dados pessoais e financeiros mapeados.....	30
C.3 Direitos dos titulares e canal de atendimento.....	30
C.4 Base legal predominante.....	30
REFERÊNCIAS.....	32



LISTA DE FIGURAS

Figura 0 - Diagrama do cenário.....	8
-------------------------------------	---



LISTA DE TABELAS

Tabela 0 - Aplicação das normas.....	10
Tabela 1 - Definição dos termos usados no documento.....	11
Tabela 2 - Riscos do cenário.....	13
Tabela 3 - Política de controle de acesso com MFA.....	15
Tabela 4 - Política de armazenamento seguro e criptografia de dados financeiros.....	16
Tabela 5 - Política de Descarte Seguro de Logs e Dados Sensíveis.....	17
Tabela 6 - Política de Escolha e Troca de Senhas.....	18
Tabela 7 - Política de Uso Controlado de Redes Sociais por Funcionários.....	19
Tabela 8 - Política de Prevenção e Tratamento de Fraudes Financeiras.....	20
Tabela 9 - Política de Gestão de Incidentes, Plano de Contingência e Continuidade.	21
Tabela 10 - Política de Governança e Gestão.....	22
Tabela 11 - Política de Privacidade e Proteção de Dados Pessoais.....	23



LISTA DE ANEXOS

ANEXO A - Termo de Ciência e Responsabilidade.....	27
ANEXO B - Plano de Ação e Implementação.....	28
ANEXO C - Diretrizes Complementares de Privacidade (LGPD / ISO 27701).....	30



LISTA DE SIGLAS E ABREVIATURAS

Sigla	Significado
AES	Advanced Encryption Standard
ANPD	Autoridade Nacional de Proteção de Dados
API	Application Programming Interface
CLT	Consolidação das Leis do Trabalho
CVV	Card Verification Value
DDoS	Distributed Denial of Service
DoA	Declaration of Applicability (Declaração de Aplicabilidade)
DPO	Data Protection Officer (Encarregado de Proteção de Dados)
DPIA	Data Protection Impact Assessment
HSM	Hardware Security Module
ISO	International Organization for Standardization
LGPD	Lei Geral de Proteção de Dados
MFA	Multi-Factor Authentication (Autenticação Multifator)
NTP	Network Time Protocol
PAN	Primary Account Number
PCI-DSS	Payment Card Industry Data Security Standard
PIMS	Privacy Information Management System
PSI	Política de Segurança da Informação
RBAC	Role-Based Access Control



RH	Recursos Humanos
RIPD	Relatório de Impacto à Proteção de Dados
ROPA	Record of Processing Activities
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SI	Segurança da Informação
SIEM	Security Information and Event Management
SIM Swap	Fraude de troca de chip telefônico
SOC	Security Operations Center
SoA	Statement of Applicability (Declaração de Aplicabilidade)
SPD	Sistema de Pagamento Digital
SGSI	Sistema de Gestão de Segurança da Informação
TLS	Transport Layer Security
TI	Tecnologia da Informação
TOTP	Time-based One-Time Password
VPN	Virtual Private Network

1. OBJETIVO

Esta Política de Segurança da Informação (PSI) estabelece as diretrizes, regras, responsabilidades e procedimentos para a proteção dos ativos de informação da NexaPay - Sistema de Pagamento Digital. Assegurando a confidencialidade, a integridade e a disponibilidade das informações financeiras e a proteção dos dados pessoais tratados no exercício de suas atividades.

O documento foi elaborado com base no processo de gestão de riscos descrito na seção 6 e está alinhado às normas técnicas e à legislação aplicável, detalhadas na seção 4. Seu cumprimento é obrigatório para toda a força de trabalho, conforme definido no escopo (seção 3).

Os objetivos específicos desta política são:

- Estabelecer regras claras de proteção dos dados financeiros e pessoais de clientes em todas as fases do processamento de pagamentos.
- Tratar os principais riscos de segurança da informação identificados para o cenário (seção 6), por meio de procedimentos específicos (seção 7), com foco em fraude, vazamento de dados e engenharia social.
- Assegurar a conformidade com a LGPD no tratamento de dados pessoais de clientes, colaboradores e terceiros.
- Definir penalidades proporcionais em caso de descumprimento, condicionadas à prévia divulgação e ciência da política (seções 8 e 9).
- Apoiar a maturidade do Sistema de Gestão de Segurança da Informação (SGSI) da Organização rumo à certificação ISO/IEC 27001.

2. DESCRIÇÃO DO CENÁRIO

A NexaPay - Sistema de Pagamento Digital é uma empresa que processa pagamentos e dados financeiros de clientes, atuando como facilitadora entre lojistas, consumidores e instituições financeiras (operadoras, bancos). O ambiente caracteriza-se pela convergência entre três domínios principais:

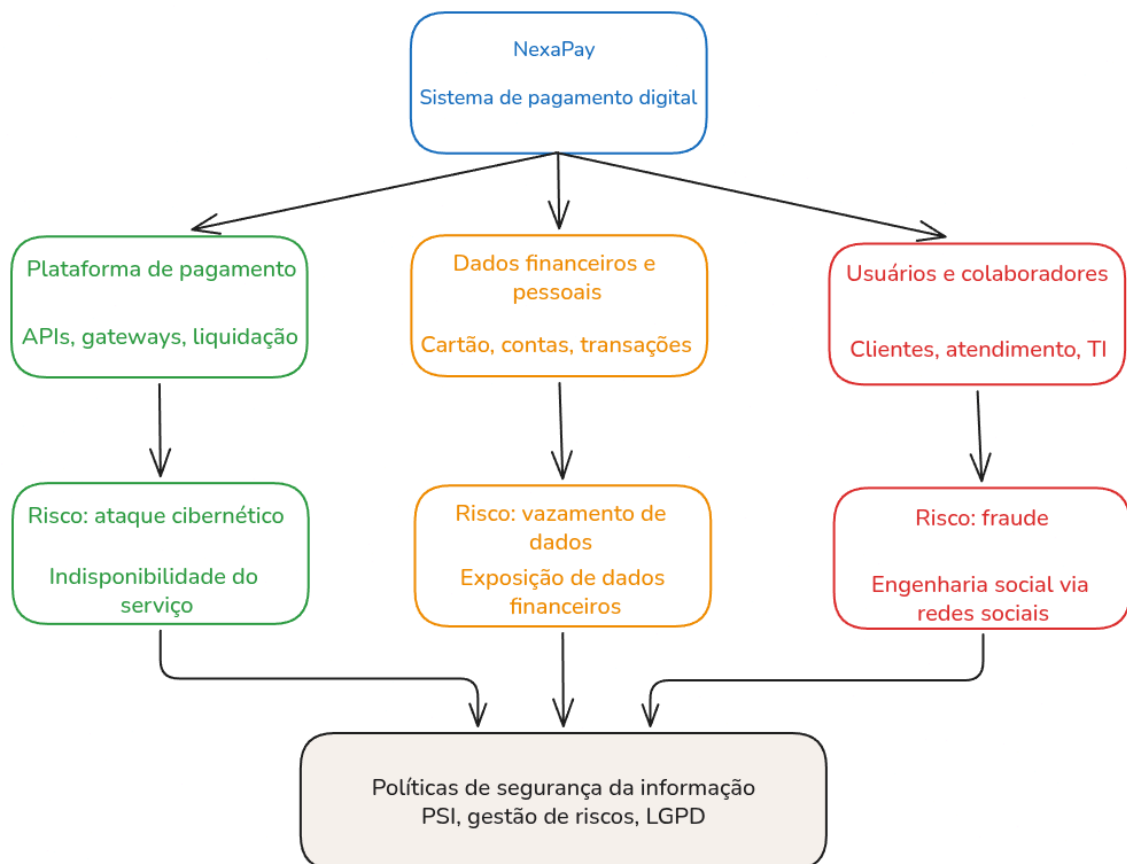
Plataforma de pagamentos: APIs, gateways e sistemas internos responsáveis pelo processamento, conciliação e liquidação de transações financeiras.

Dados financeiros e pessoais: informações de cartão (tokenizadas), contas bancárias, históricos de transação e dados cadastrais de clientes e colaboradores.

Usuários e colaboradores: clientes que realizam transações pela plataforma e colaboradores que operam sistemas administrativos, atendimento, antifraude e desenvolvimento.

Essa convergência amplia a superfície de ataque: uma falha de segurança em qualquer um dos domínios pode resultar em fraude financeira, vazamento de dados sensíveis ou indisponibilidade do serviço de pagamentos. Os principais riscos a tratar são fraudes financeiras, vazamento de dados financeiros e engenharia social via redes sociais, todos detalhados na seção 6.

Figura 0 - Diagrama do cenário



Fonte: Elaboração própria

3. ESCOPO

Esta política se aplica a toda a força de trabalho: colaboradores próprios (áreas administrativas, de TI, desenvolvimento, atendimento e antifraude), estagiários, terceiros, prestadores de serviço e fornecedores com acesso a informações, sistemas ou dados financeiros da Organização.

Abrange os ambientes de produção, homologação e desenvolvimento, incluindo acessos remotos e serviços utilizados no processamento de pagamentos. Esta política aplica-se a:

- Todos os ativos de informação (dados, sistemas, aplicações, redes, APIs e documentos), independentemente do formato ou meio de armazenamento.
- Dados financeiros e dados pessoais de clientes, colaboradores e terceiros, tratados em qualquer fase do ciclo de vida da informação (coleta, uso, armazenamento, compartilhamento e descarte).
- Os procedimentos vinculados, listados na seção 7, que detalham as regras específicas por tema e os controles de segurança adotados pela Organização.

4. REFERÊNCIAS NORMATIVAS

As diretrizes desta política derivam das normas e da legislação a seguir. Em cada procedimento (seção 7) são citados os controles específicos utilizados, formando a base para a futura Declaração de Aplicabilidade (DoA/SoA) do SGSI.

Tabela 0 - Aplicação das normas

Norma / referência	Aplicação nesta política
ABNT NBR ISO/IEC 27001:2022	Requisitos do Sistema de Gestão de Segurança da Informação (SGSI). Aplicadas as cláusulas 4 (contexto da organização), 5 (liderança e política), 6.1 (ações para abordar riscos e oportunidades), 6.2 (objetivos de SI), 7.2/7.3 (competência, conscientização), 7.5 (informação documentada), 8 (operação), 9 (avaliação de desempenho, auditoria interna e análise crítica) e 10 (melhoria contínua).
ABNT NBR ISO/IEC 27002:2022	Catálogo de controles de segurança da informação, organizados em 4 temas: organizacionais (cláusula 5), pessoas (cláusula 6), físicos (cláusula 7) e tecnológicos (cláusula 8). Cada procedimento da seção 7 refere-se aos controles específicos utilizados, formando a base da futura Declaração de Aplicabilidade (DoA/SoA) do SGSI.
ABNT NBR ISO/IEC 27005:2023	Orientações para o processo de gestão de riscos de segurança da informação (identificação, análise, avaliação, tratamento, aceitação, comunicação e monitoramento de riscos), aplicada como metodologia detalhada na seção 6 e na construção da matriz de riscos.
ABNT NBR ISO 31000:2018	Princípios, estrutura (framework) e processo genérico de gestão de riscos corporativos, adotados como referência estrutural do processo de gestão de riscos (seção 6) e do plano de continuidade de negócio (seção 7.7).
ABNT NBR ISO/IEC 27701:2026	Extensão da ISO/IEC 27001/27002 para gestão da privacidade da informação (PIMS), incluindo papéis de controlador e operador de dados pessoais, base legal, direitos dos titulares e medidas de proteção de dados, aplicada ao tratamento de dados pessoais de clientes e colaboradores (Anexo C).
ABNT NBR ISO/IEC 27557:2023	Orientações para a gestão de riscos de privacidade organizacional, aplicada à avaliação de riscos de privacidade decorrente do tratamento de dados financeiros e pessoais em logs de transações (R-05, R-09).
LGPD - Lei nº 13.709/2018	Princípios e bases legais para o tratamento de dados pessoais (arts. 6º e 7º), medidas técnicas e administrativas de segurança (arts. 46 e 47), término do tratamento e eliminação de dados (arts. 15 e 16), comunicação de incidentes de segurança à ANPD e aos titulares (art. 48), e sanções administrativas (art. 52).
PCI-DSS	Padrão de segurança de dados do setor de cartões de pagamento, referenciado como boa prática complementar para tokenização, segmentação de rede de pagamento e armazenamento restrito de dados de cartão (PAN), sem prejuízo da adoção plena das normas ISO/LGPD acima.

5. TERMOS E DEFINIÇÕES

Tabela 1 - Definição dos termos usados no documento

Termo	Definição
Ativo de informação	Informação ou recurso que armazena, processa, transmite ou suporta informações e que possui valor para a Organização.
Ameaça	Causa potencial de um incidente capaz de explorar vulnerabilidades e causar danos à Organização.
Vulnerabilidade	Fraqueza ou deficiência de um ativo, processo ou controle que pode ser explorada por uma ameaça.
Risco	Efeito da incerteza sobre os objetivos da Organização, normalmente avaliado pela combinação entre probabilidade e impacto.
Incidente de segurança da informação	Evento que compromete ou tem potencial de comprometer a confidencialidade, a integridade ou a disponibilidade das informações.
PAN (Primary Account Number)	Número de identificação do cartão de pagamento, considerado dado restrito e sujeito a tokenização.
Tokenização	Processo de substituição de um dado sensível (ex.: número de cartão) por um identificador (token) sem valor explorável fora do contexto da transação.
MFA (Multi-Factor Authentication)	Autenticação multifator, que exige dois ou mais fatores de verificação independentes (algo que se sabe, algo que se tem, algo que se é).
Dados pessoais (DP)	Informação relacionada a pessoa natural identificada ou identificável, conforme a LGPD.
Titular de dados	Pessoa natural a quem se referem os dados pessoais que são objeto de tratamento.
Encarregado (DPO)	Pessoa indicada pela Organização para atuar como canal de comunicação entre o controlador, os titulares dos dados e a ANPD, conforme art. 41 da LGPD.
RBAC (Role-Based Access Control)	Modelo de controle de acesso baseado em papéis/funções, no qual os privilégios são atribuídos conforme a função exercida pelo usuário.
RTO / RPO	Objetivo de Tempo de Recuperação (Recovery Time Objective) e Objetivo de Ponto de Recuperação (Recovery Point Objective), métricas utilizadas no plano de continuidade de negócios.

6. GESTÃO DE RISCOS

A gestão de riscos segue o processo estabelecido pela ABNT NBR ISO 31000:2018, especializado para segurança da informação pela ABNT NBR ISO/IEC 27005:2023, compreendendo as etapas de estabelecimento do contexto, identificação, análise, avaliação, tratamento, aceitação, comunicação/consulta e monitoramento/análise crítica dos riscos.

O nível de risco é obtido pela combinação de Probabilidade (P) e Impacto (I), ambos avaliados em escala de 1 a 5:

Nível de Risco = Probabilidade (P) × Impacto (I)

- Baixo: 1 a 4
- Médio: 5 a 9
- Alto: 10 a 14
- Crítico: 15 a 25

6.1 Critérios de Aceitação e Tratamento de Riscos

Conforme os princípios da ABNT NBR ISO 31000:2018 e da ABNT NBR ISO/IEC 27005:2023, os riscos identificados são tratados de acordo com seu nível, podendo ser:

- Mitigar: implementação de controles para reduzir a probabilidade e/ou o impacto do risco (opção adotada para todos os riscos identificados nesta política, em razão de sua criticidade Alta a Crítica).
- Evitar: eliminação da atividade ou condição que dá origem ao risco, quando aplicável e tecnicamente viável.
- Transferir/Compartilhar: por meio de contratos, seguros (ex.: seguro cibernético) ou cláusulas com terceiros (operadoras, adquirentes, processadoras).
- Aceitar: somente para riscos residuais classificados como Baixo, após aplicação dos controles, mediante registro formal e aprovação do Comitê de Segurança da Informação.

Riscos classificados como Alto ou Crítico exigem plano de ação com responsável e prazo definidos, monitoramento contínuo e reavaliação na revisão periódica da política (seção 10).

A tabela a seguir consolida os riscos identificados para o cenário, com a opção de tratamento (mitigar) e os controles da ISO/IEC 27002:2022 que os endereçam - os mesmos refletidos nos procedimentos da seção 7 e que comporão a Declaração de Aplicabilidade do SGSI.

Tabela 2 - Riscos do cenário

ID	Ativo / Processo	Ameaça	Vulnerabilidade	P	I	Nível	Tratamento e controles ISO/IEC 27002:2022
R-01	Dados financeiros de clientes (cartão, conta, transações)	Vazamento / exfiltração de dados financeiros	Dados sem criptografia/to kenização em repouso	3	5	Crítico	Mitigar: 8.24, 8.12, 5.12, 5.34
R-02	Plataforma de pagamentos (API, gateway)	Fraude financeira (transações não autorizadas)	Ausência de MFA e de validação robusta de transações	4	5	Crítico	Mitigar: 5.17, 8.5, 8.16, 8.23
R-03	Credenciais de usuários e colaboradores	Acesso não autorizado / takeover de conta	Senhas fracas, reutilizadas ou sem MFA	4	4	Crítico	Mitigar: 5.16, 5.17, 8.5
R-04	Colaboradores (engenharia social)	Phishing / engenharia social via redes sociais	Uso irrestrito de redes sociais e exposição de informações corporativas	3	4	Alto	Mitigar: 5.10, 6.3, 8.1, 8.23
R-05	Logs de transações e acessos	Perda de evidência / exposição de dados financeiros e pessoais	Sem política de retenção e descarte seguro de logs	3	4	Alto	Mitigar: 8.10, 8.15, 7.14, 5.33
R-06	Canais de comunicação (TLS/API)	Interceptação de dados em trânsito	Uso de protocolos desatualizado	2	5	Alto	Mitigar: 8.24, 8.20, 8.9

		(man-in-the-middle)	s ou sem TLS forte				
R-07	Ambiente de desenvolvimento/homologação	Vazamento de credenciais e dados reais em ambientes não produtivos	Uso de dados reais sem mascaramento e credenciais hardcoded	3	4	Alto	Mitigar: 8.31, 8.28, 8.5
R-08	Infraestrutura de processamento (servidores/cloud)	Indisponibilidade do serviço (DDoS, falha de infraestrutura)	Falta de redundância e de plano de continuidade testado	2	5	Alto	Mitigar: 5.29, 5.30, 8.14, 8.6
R-09	Dados pessoais de clientes e colaboradores	Tratamento inadequado de dados pessoais (LGPD)	Ausência de inventário de dados pessoais (ROPA) e de DPIA/RIPD	3	4	Alto	Mitigar: 5.34, 8.4 + ISO/IEC 27701/27557; LGPD art. 6º, 7º, 37, 38
R-10	Cadeia de suprimentos (operadoras, processadoras, gateways)	Comprometimento via terceiros (fornecedor de pagamento)	Ausência de avaliação de segurança e cláusulas contratuais com terceiros	2	5	Alto	Mitigar: 5.19, 5.20, 5.21, 5.22
R-11	Estações de trabalho administrativas	Malware / ransomware via redes sociais e e-mail	Endpoint sem proteção adequada e usuários sem treinamento	3	4	Alto	Mitigar: 8.7, 8.1, 6.3, 5.10

7. PROCEDIMENTOS E POLÍTICAS ESPECÍFICAS

Cada procedimento abaixo é um documento controlado, com finalidade, autoria, versão, aprovação e vigência próprias. A autoria está distribuída entre os membros do grupo, em segregação de funções, e cada procedimento referencia explicitamente os controles normativos e os riscos da seção 6 que endereça.

7.1 Controle de Acesso com Autenticação Multifator (MFA)

Tabela 3 - Política de controle de acesso com MFA

Finalidade / Objetivo	Garantir que o acesso aos sistemas de pagamento, dados financeiros e ambientes administrativos ocorra apenas por pessoas autorizadas, com verificação adicional de identidade por meio de MFA.
Autoria	Gustavo - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

Controle de acesso lógico

- Controle de acesso baseado em papéis (RBAC), segmentado por função (operação, suporte, financeiro, desenvolvimento, administração de infraestrutura), com aplicação do princípio do menor privilégio e segregação de funções.
- Contas individuais e nominais; o compartilhamento de credenciais é proibido. Contas de serviço (integrações entre sistemas) são documentadas e armazenadas em cofre de segredos.
- Concessão, alteração e revogação de acesso por processo formal (workflow de aprovação), com revogação imediata no desligamento ou mudança de função; revisão dos direitos de acesso no mínimo trimestral para sistemas que tratam dados financeiros.

Autenticação multifator (MFA)

- MFA obrigatório para todos os acessos a sistemas que processam pagamentos, dados financeiros, painéis administrativos e ambientes de produção, sem exceção.
- MFA obrigatório também para clientes em operações de alto risco (alteração de dados cadastrais, cadastro de novos beneficiários, transações acima de limites definidos pela área de risco).
- Métodos aceitos: aplicativo autenticador (TOTP), token físico (preferencial para perfis administrativos) ou biometria; SMS é admitido apenas como fator secundário de menor criticidade, dada sua vulnerabilidade a SIM swap.

- Sessões privilegiadas (acesso a banco de dados de produção, infraestrutura cloud, painéis de antifraude) exigem MFA renovado a cada nova sessão e bloqueio automático por inatividade.

Acessos remotos e privilegiados

- Acesso remoto à infraestrutura de produção somente via VPN corporativa com MFA e por meio de jump server, com sessão registrada (gravação/log).
- Acessos privilegiados (administradores de banco de dados, infraestrutura, segurança) utilizam contas dedicadas (PAM - Privileged Access Management), distintas das contas de uso diário.

Base normativa: ISO/IEC 27002:2022 - 5.15, 5.16, 5.17, 5.18, 8.2, 8.3, 8.5; ISO/IEC 27001:2022 - cláusulas 6.1 e 8; LGPD - art. 46.
Riscos tratados: R-02, R-03, R-07.

7.2 Armazenamento Seguro e Criptografia de Dados Financeiros

Tabela 4 - Política de armazenamento seguro e criptografia de dados financeiros

Finalidade / Objetivo	Proteger os dados financeiros e pessoais de clientes (números de cartão, contas, históricos de transação) em repouso e em trânsito, por meio de classificação da informação, criptografia e tokenização.
Autoria	Maria Eduarda - Setor de TI/Infraestrutura - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Classificação dos dados em público, interno, confidencial e restrito; dados financeiros (números de cartão, contas bancárias, saldos, histórico de transações) e dados pessoais sensíveis são sempre classificados como restritos.
- Criptografia em repouso: AES-256 para bancos de dados, backups e mídias que contenham dados confidenciais ou restritos.
- Tokenização de dados de cartão (PAN): o número completo do cartão (PAN) é substituído por um token nos sistemas internos; o PAN original é armazenado apenas no cofre de tokenização (token vault), segregado e com acesso altamente restrito - alinhado às boas práticas do PCI-DSS.

- Criptografia em trânsito: TLS 1.2 ou superior (preferencialmente 1.3) em todas as comunicações entre sistemas, APIs e integrações com adquirentes/processadoras; VPN com criptografia forte para acessos remotos.
- Gestão de chaves criptográficas: chaves protegidas em HSM (Hardware Security Module) ou cofre de segredos equivalente, com rotação periódica, custódia formalizada e segregação entre quem administra dados e quem administra chaves.
- Backups criptografados, com cópia externa (off-site) e testes periódicos de restauração (integra o P-07).
- Mascaramento de dados (data masking) em ambientes de desenvolvimento, teste e homologação - dados reais de clientes não podem ser utilizados sem anonimização ou pseudonimização (mitiga R-07).

Base normativa: ISO/IEC 27002:2022 - 5.12, 5.14, 8.12, 8.24, 8.28, 8.31; ISO/IEC 27001:2022 - cláusula 8; LGPD - art. 46 e 47; PCI-DSS (referência complementar para tokenização).

Riscos tratados: R-01, R-06, R-07.

7.3 Descarte Seguro de Logs e Dados Sensíveis

Tabela 5 - Política de Descarte Seguro de Logs e Dados Sensíveis

Finalidade / Objetivo	Definir a geração, proteção, retenção e o descarte seguro de logs de transações, acessos e demais dados sensíveis, preservando evidências para auditoria e atendendo à LGPD.
Autoria	Rafael - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Geração de logs de transações financeiras, autenticação, acessos administrativos e eventos de antifraude, com sincronização de relógio (NTP) para correlação de eventos.
- Proteção da integridade dos logs: acesso restrito a perfis autorizados, armazenamento em modo somente leitura (write-once) e proteção contra adulteração, sobretudo para logs de transações (evidência para disputas e chargebacks).

- Mascaramento ou supressão de dados sensíveis (PAN, CVV, senhas) nos registros de log - dados de cartão nunca são armazenados em texto claro em arquivos de log.
- Retenção: período de referência de 6 meses on-line e 12 a 60 meses em arquivo (conforme exigências regulatórias do setor financeiro e prazos de prescrição), com logs de dados pessoais seguindo os princípios de minimização e finalidade da LGPD.
- Monitoramento e análise periódica dos logs (idealmente via SIEM/SOC) para detecção de fraudes, anomalias e tentativas de acesso indevido, integrando-se ao P-07.
- Descarte seguro: ao final do período de retenção, exclusão lógica segura dos dados e sanitização/destruição física das mídias, com registro formal do descarte. O descarte ad hoc por colaboradores é expressamente proibido.

Base normativa: ISO/IEC 27002:2022 - 5.33, 5.34, 7.14, 8.10, 8.15, 8.16, 8.17; ISO/IEC 27001:2022 - cláusulas 8 e 9; ISO/IEC 27557:2023 (gestão de riscos de privacidade); LGPD - art. 15, 16 e 46.

Riscos tratados: R-05, R-09.

7.4 Política de Escolha e Troca de Senhas (Alta Criticidade)

Tabela 6 - Política de Escolha e Troca de Senhas

Finalidade / Objetivo	Estabelecer regras rígidas de criação, uso, troca e proteção de senhas e demais credenciais, em razão da alta criticidade dos sistemas de pagamento.
Autoria	Gustavo - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Tamanho mínimo de 14 caracteres para contas administrativas e de produção, e de 12 caracteres para demais contas, com exigência de complexidade (maiúsculas, minúsculas, números e símbolos); senhas óbvias, padrão de fábrica ou previamente comprometidas (verificadas contra listas de senhas vazadas) são proibidas.
- Troca obrigatória imediata em caso de suspeita de comprometimento; troca periódica de senhas de contas privilegiadas (administradores, infraestrutura, antifraude) conforme política de risco, com histórico que impede reutilização das últimas senhas.
- É vedado compartilhar, anotar ou exibir senhas de forma visível (mesa limpa e tela limpa); senhas nunca são enviadas por e-mail, chat ou mensageiro sem criptografia.

- Bloqueio automático de conta após número definido de tentativas mal sucedidas, com notificação ao usuário e à equipe de segurança em caso de bloqueio por possível ataque de força bruta.
- MFA obrigatório (conforme P-01) como camada adicional independente da senha, especialmente para acesso a sistemas de pagamento e dados financeiros.
- Credenciais de serviço e chaves de API são armazenadas em cofre de segredos (vault); o registro de senhas, tokens ou chaves em texto puro em código-fonte, planilhas, scripts ou repositórios (hardcoding) é proibido e monitorado por varredura automatizada.

Base normativa: ISO/IEC 27002:2022 - 5.16, 5.17, 5.18, 8.5, 8.28; ISO/IEC 27001:2022 - cláusula 8; LGPD - art. 46.

Riscos tratados: R-02, R-03.

7.5 Uso Controlado de Redes Sociais por Funcionários

Tabela 7 - Política de Uso Controlado de Redes Sociais por Funcionários

Finalidade / Objetivo	Restringir e orientar o uso de redes sociais por colaboradores, reduzindo o risco de engenharia social, phishing e vazamento de informações sobre a empresa e seus clientes.
Autoria	Maria Eduarda - Setor de TI/Infraestrutura - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- O acesso a redes sociais pessoais é restrito nas estações de trabalho que processam dados financeiros, acessam sistemas de pagamento ou ambientes de produção; uso permitido apenas em redes/equipamentos segregados, fora do horário de trabalho ou em áreas de convivência.
- Filtragem de conteúdo web, com bloqueio de categorias de risco (redes sociais não corporativas, mensageiros pessoais, sites de proxy/anonimização) nas estações que possuem acesso a sistemas críticos.
- Proibição de compartilhamento, em redes sociais corporativas ou pessoais, de informações sobre clientes, transações, arquitetura de sistemas, processos internos, capturas de tela de painéis administrativos ou credenciais.
- Programa de conscientização contínua sobre redes sociais como vetor de engenharia social e phishing direcionado (spear phishing), incluindo simulações periódicas de phishing com métricas de resposta da equipe.
- Perfis corporativos oficiais (marketing, atendimento ao cliente) são gerenciados por equipe autorizada, em estações segregadas da rede de produção, com diretrizes específicas de comunicação e sem divulgação de dados sensíveis.
- Verificação de identidade adicional para qualquer solicitação recebida via redes sociais que envolva dados de clientes, redefinição de senha ou alteração de

dados cadastrais - tais canais não substituem os canais oficiais de atendimento.

Base normativa: ISO/IEC 27002:2022 - 5.10, 6.3, 8.1, 8.7, 8.23; ISO/IEC 27001:2022 - cláusulas 7.3 e 8.
Riscos tratados: R-04, R-11.

7.6 Prevenção e Tratamento de Fraudes Financeiras

Tabela 8 - Política de Prevenção e Tratamento de Fraudes Financeiras

Finalidade / Objetivo	Estabelecer controles para prevenção, detecção, investigação e resposta a fraudes em transações de pagamento, protegendo clientes e a operação da empresa.
Autoria	Rafael - Setor de TI/Segurança - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Implementação de motor de antifraude com análise de risco em tempo real (regras + modelos comportamentais), considerando geolocalização, dispositivo, horário, valor e padrão histórico da transação.
- Definição de limites e alçadas de transação por perfil de cliente, com verificação adicional (MFA/passos extras de autenticação) para transações de maior valor ou fora do padrão.
- Monitoramento contínuo de indicadores de fraude (chargebacks, contestações, tentativas de transação recusadas), com revisão periódica das regras de antifraude pela equipe de risco.
- Procedimento formal de investigação de suspeitas de fraude, incluindo bloqueio preventivo da transação/conta, comunicação ao cliente e, quando aplicável, às operadoras/adquirentes e órgãos competentes.
- Treinamento específico para as equipes de atendimento e suporte sobre técnicas comuns de fraude (engenharia social, contas tomadas - account takeover, fraude no cadastro) e procedimentos de verificação de identidade.
- Registro e análise de incidentes de fraude como entrada para a revisão periódica da matriz de riscos (seção 6) e do plano de ação (Anexo B).

Base normativa: ISO/IEC 27002:2022 - 5.7 (inteligência de ameaças), 5.25, 5.26, 8.16, 8.23; ISO/IEC 27001:2022 - cláusulas 6.1, 8 e 9.
Riscos tratados: R-02, R-03, R-04.

7.7 Gestão de Incidentes, Plano de Contingência e Continuidade

Tabela 9 - Política de Gestão de Incidentes, Plano de Contingência e Continuidade

Finalidade / Objetivo	Detectar, responder e recuperar-se de incidentes de segurança da informação, assegurando a continuidade do processamento de pagamentos durante interrupções.
Autoria	Equipe / Comitê de SI - Gustavo, Maria Eduarda e Rafael - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

Gestão de incidentes

- Canal e procedimento claros para o reporte tempestivo de eventos e incidentes de segurança por qualquer colaborador, terceiro ou fornecedor, incluindo um canal específico para suspeitas de fraude.
- Classificação, contenção, erradicação e recuperação de incidentes, com critérios de escalonamento definidos conforme a criticidade (severidade baixa, média, alta e crítica) e o impacto sobre o processamento de pagamentos.
- Coleta e preservação de evidências (logs, registros de transação, imagens forenses) para apuração e eventual responsabilização disciplinar, civil ou criminal, e para atendimento a auditorias de operadoras/adquirentes.

Plano de contingência (reação imediata)

- Isolar sistemas, contas ou componentes comprometidos, evitando a propagação do incidente a outros serviços de pagamento.
- Ativar processamento alternativo (rota de contingência com adquirente/processadora secundária) quando aplicável, para minimizar a indisponibilidade do serviço.
- Comunicar imediatamente as partes interessadas (gestão, equipe de TI/segurança/risco, e quando necessário clientes, parceiros financeiros e autoridades).

Plano de continuidade

- Manter o processamento de pagamentos essencial durante a interrupção, por meio de redundância de sistemas críticos (infraestrutura em múltiplas zonas/regiões), backups testados periodicamente e prontidão da infraestrutura de TIC.
- Definição de objetivos de tempo de recuperação (RTO) e ponto de recuperação (RPO) para os sistemas críticos identificados na seção 6.
- Testes periódicos do plano de continuidade (simulações/exercícios de mesa, testes de failover), com registro de lições aprendidas e atualização do plano.

Conformidade com a LGPD

- Comunicação à Autoridade Nacional de Proteção de Dados (ANPD) e aos titulares afetados em incidentes que envolvam dados pessoais ou financeiros, quando aplicável, conforme prazos e critérios definidos pela ANPD.

- Registro formal de lições aprendidas após cada incidente relevante, com atualização da matriz de riscos e dos procedimentos pertinentes.

Base normativa: ISO/IEC 27002:2022 - 5.24, 5.25, 5.26, 5.27, 5.28, 5.29, 5.30, 6.8, 8.13, 8.14; ISO/IEC 27001:2022 - cláusulas 8 e 10; ISO 31000:2018 (estrutura geral de gestão de riscos); LGPD - art. 48.

Riscos tratados: R-02, R-08 (resposta direta); R-08 e demais (resiliência geral).

7.8 Governança da Cadeia de Suprimentos e Gestão de Fornecedores

Financeiros

Tabela 10 - Política de Governança e Gestão

Finalidade / Objetivo	Estabelecer requisitos de segurança da informação para operadoras, adquirentes, processadoras de pagamento e demais fornecedores que tenham acesso a sistemas ou dados financeiros, reduzindo riscos introduzidos pela cadeia de suprimentos.
Autoria	Maria Eduarda - Setor de TI/Infraestrutura - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Avaliação de segurança da informação de fornecedores críticos (operadoras, adquirentes, processadoras, provedores de antifraude) antes da contratação (due diligence), proporcional ao risco e ao volume financeiro envolvido.
- Inclusão de cláusulas contratuais de segurança da informação e privacidade (confidencialidade, direito de auditoria, notificação de incidentes, retorno/destruição de dados ao final do contrato, conformidade com PCI-DSS quando aplicável).
- Concessão de acessos a integrações de terceiros (APIs, webhooks) segue o mesmo processo formal do P-01 (autenticação forte, escopos mínimos de permissão, revisão periódica) e é restrita ao estritamente necessário e ao período do contrato.
- Monitoramento periódico do desempenho de segurança dos fornecedores críticos, incluindo, quando aplicável, certificações (ex.: ISO/IEC 27001, PCI-DSS) e relatórios de auditoria (SOC 2, etc.).
- Gestão de mudanças em serviços de fornecedores (atualizações de API, novas integrações, alteração de escopo) submetida a análise de impacto em segurança da informação antes da implementação.

Base normativa: ISO/IEC 27002:2022 - 5.19, 5.20, 5.21, 5.22, 5.23; ISO/IEC 27001:2022 - cláusulas 6.1, 8 e 9.

Riscos tratados: R-10.

7.9 Privacidade e Proteção de Dados Pessoais (LGPD)

Tabela 11 - Política de Privacidade e Proteção de Dados Pessoais

Finalidade / Objetivo	Estabelecer diretrizes para o tratamento de dados pessoais de clientes, colaboradores e terceiros, em conformidade com a LGPD e com a ABNT NBR ISO/IEC 27701 (Sistema de Gestão da Privacidade da Informação).
Autoria	Rafael - Setor de TI/Segurança - Setor de TI/Segurança, em apoio ao Encarregado de Dados (DPO) - 01/06/2026
Revisão	1.0
Aprovação	Comitê de Segurança da Informação / Direção - 10/06/2026
Vigência	Início 12/06/2026; validade 12 meses (revisão até 12/06/2027)

- Designação formal de um Encarregado pelo Tratamento de Dados Pessoais (DPO), responsável pelo canal de comunicação com titulares e com a ANPD.
- Manutenção de inventário de dados pessoais e registro das operações de tratamento (ROPA - Record of Processing Activities), identificando finalidade, base legal, prazo de retenção e medidas de segurança aplicadas, com destaque para dados financeiros de clientes.
- Aplicação dos princípios da LGPD: finalidade, adequação, necessidade, livre acesso, qualidade dos dados, transparência, segurança, prevenção, não discriminação e responsabilização (art. 6º).
- Realização de Relatório de Impacto à Proteção de Dados Pessoais (RIPD/DPIA) para tratamentos de alto risco, incluindo o uso de motores de antifraude baseados em perfilamento de clientes.
- Atendimento aos direitos dos titulares (confirmação, acesso, correção, eliminação, portabilidade, entre outros previstos no art. 18 da LGPD), por meio de canal formal e prazos definidos.
- Integração com o P-03 (retenção e descarte de logs com dados pessoais e financeiros) e com o P-07 (comunicação de incidentes envolvendo dados pessoais).

Base normativa: ABNT NBR ISO/IEC 27701:2026 (papéis de controlador/operador, base legal, direitos dos titulares); ABNT NBR ISO/IEC 27557:2023 (gestão de riscos de privacidade); ISO/IEC 27002:2022 - 5.34; LGPD - arts. 6º, 7º, 8º, 9º, 18, 37, 38, 41 e 46 a 49.

Riscos tratados: R-09.

8. PENALIDADE POR VIOLAÇÃO

O descumprimento desta política e de seus procedimentos vinculados sujeita o infrator a medidas disciplinares, apuradas por meio de processo disciplinar formal que assegure o contraditório, a ampla defesa e a proporcionalidade entre a sanção aplicada e a gravidade da conduta.

A gradação das sanções observa a gravidade da violação e a reincidência do infrator:

- Leve: orientação ou advertência verbal, com registro no histórico do colaborador.
- Moderada: advertência por escrito.
- Grave: suspensão do contrato de trabalho e suspensão temporária dos acessos a sistemas financeiros, sem prejuízo de revisão de privilégios.
- Gravíssima ou reincidente: rescisão do contrato de trabalho por justa causa (CLT, art. 482), sem prejuízo da responsabilização civil e criminal cabível, especialmente em casos de fraude ou vazamento intencional de dados financeiros.
- Terceiros e fornecedores: notificação formal, suspensão do acesso e, conforme a gravidade, rescisão contratual, observadas as cláusulas de segurança da informação previstas nos contratos (P-08).

A aplicação de qualquer penalidade está condicionada à comprovação de que o infrator teve ciência prévia desta política e dos procedimentos vinculados, conforme registro previsto na seção 9.

Base normativa: ISO/IEC 27002:2022 - 6.4 (processo disciplinar) e 5.20 (acordos com fornecedores); CLT - art. 482.

9. DIVULGAÇÃO, CONSCIENTIZAÇÃO E CIÊNCIA

Para que as penalidades previstas na seção 8 sejam aplicáveis, a Organização garante a ampla divulgação desta política e o registro formal da ciência por parte de toda a força de trabalho, utilizando meios adequados ao público de destino.

- Assinatura do Termo de Ciência e Responsabilidade (Anexo A) no momento da admissão e a cada revisão relevante da política.
- Treinamento de integração (admissional) e reciclagem periódica, no mínimo anual, com registros mantidos como evidência para auditoria, incluindo módulo específico sobre fraude e engenharia social.



- Divulgação por múltiplos canais: intranet, e-mail corporativo, murais e comunicados internos, e campanhas periódicas de conscientização.
- A política permanece disponível e versionada em repositório controlado; mudanças relevantes são comunicadas formalmente a toda a força de trabalho.
- A ciência registrada é condição indispensável para a aplicação das penalidades previstas na seção 8.

10. APROVAÇÃO, VIGÊNCIA E REVISÃO

Esta política entra em vigor em 12/06/2026, tem validade de 12 meses e deve ser revisada ao menos anualmente, ou antes desse prazo diante de mudança relevante (novo risco identificado, incidente significativo, alteração tecnológica, organizacional ou legal).

É um documento controlado, com histórico de versões mantido pelo Comitê de Segurança da Informação. Toda nova versão deve ser submetida ao mesmo processo de aprovação e divulgação descrito na seção 9.

Aprovado por: Comitê de Segurança da Informação / Direção

Data: 12 de Jun. 2026

Participante	Função	Assinatura
Gustavo Henrique da Silva Kubiack	Direção	GustavoKubiack
Maria Eduarda Nichelle Ferreira	Comitê de Segurança da Informação	Maria
Rafael Francisco Gonçalves Serrano	Comitê de Segurança da Informação	Rafael



ANEXO A - Termo de Ciência e Responsabilidade

Declaro que recebi, li e compreendi a Política de Segurança da Informação da NexaPay. (versão 1.0) e os procedimentos a ela vinculados (P-01 a P-09), comprometendo-me a cumpri-los integralmente. Estou ciente de que o descumprimento sujeita-se às penalidades previstas na seção 8, sem prejuízo das responsabilidades civis e criminais aplicáveis.

Nome: _____

Setor / Função: _____

Matrícula: _____ Data: ____ / ____ / ____

Assinatura: _____

ANEXO B - Plano de Ação e Implementação

ID	Ação	Responsável	Prazo	Riscos relacionados
1	Constituir formalmente o Comitê de Segurança da Informação e designar o Encarregado de Dados (DPO)	Direção	30 dias	R-09, todos
2	Implementar MFA obrigatório para sistemas de pagamento, acessos administrativos e operações de alto risco	TI/Segurança	60 dias	R-02, R-03
3	Implementar tokenização do PAN e criptografia AES-256/TLS 1.3 para dados financeiros	TI/Infraestrutura	90 dias	R-01, R-06
4	Implantar política de senhas reforçada e cofre de segredos (vault) para credenciais de serviço	TI/Segurança	60 dias	R-02, R-03
5	Implementar mascaramento de dados em ambientes de desenvolvimento/homologação	TI/Desenvolvimento	90 dias	R-07
6	Implementar política de retenção, mascaramento e descarte seguro de logs (SIEM)	TI/Segurança	90 dias	R-05, R-09
7	Restringir acesso a redes sociais em estações críticas e iniciar campanhas de conscientização/phishing simulado	TI/Infraestrutura, RH	45 dias	R-04, R-11
8	Implantar/aprimorar motor de antifraude com regras e alçadas por perfil de cliente	Risco/Antifraude	120 dias	R-02, R-04
9	Formalizar contratos com cláusulas de segurança e avaliar operadoras/processadoras críticas	Compras/Jurídico/TI	120 dias	R-10
10	Elaborar e testar plano de contingência e continuidade (failover, simulação de incidente)	Comitê de SI	150 dias	R-02, R-08
11	Realizar ROPA (inventário de dados pessoais e financeiros) e RIPD para o motor de antifraude	DPO	90 dias	R-09
12	Treinamento admissional e campanha contínua de conscientização para toda a força de trabalho	RH/Comitê de SI	60 dias	todos

Evidências necessárias para auditoria

- Ata de constituição do Comitê de SI e designação formal do DPO.
- Configurações e logs de MFA em sistemas de pagamento e acessos administrativos.
- Evidências de tokenização do PAN, configurações de TLS, uso de HSM/cofre de chaves.

- Política de senhas, configurações de bloqueio de conta e relatório do cofre de segredos.
- Evidências de mascaramento de dados em ambientes não produtivos.
- Relatórios de retenção e descarte de logs, com registros de sanitização de mídias.
- Relatórios de bloqueio de redes sociais, registros de treinamento e resultados de simulações de phishing.
- Relatórios do motor de antifraude, regras vigentes e histórico de revisões.
- Contratos com cláusulas de segurança, relatórios de avaliação de fornecedores/operadoras.
- Plano de contingência/continuidade, registros de testes e simulações, RTO/RPO definidos.
- ROPA, RIPDs realizados, registros de atendimento a titulares e eventuais comunicações à ANPD.
- Termos de Ciência assinados (Anexo A) e registros de treinamento/conscientização.

ANEXO C - Diretrizes Complementares de Privacidade (LGPD / ISO 27701)

Este anexo complementa o procedimento P-09, detalhando papéis, fluxos de dados pessoais e medidas alinhadas à ABNT NBR ISO/IEC 27701:2026, que estende o SGSI (ISO/IEC 27001/27002) para a gestão da privacidade da informação.

C.1 Papéis e responsabilidades

Papel	Descrição
Controlador	NexaPay., responsável pelas decisões referentes ao tratamento de dados pessoais e financeiros de clientes.
Operador	Operadoras, adquirentes, processadoras de pagamento e demais fornecedores que tratam dados pessoais/financeiros em nome da Organização.
Encarregado (DPO)	Profissional designado pela Direção, responsável pelo canal de comunicação com titulares e com a ANPD, e pela supervisão do cumprimento desta política de privacidade.
Titulares de dados	Clientes (pagadores e recebedores), colaboradores, candidatos a emprego e terceiros cujos dados pessoais sejam tratados pela Organização.

C.2 Principais fluxos de dados pessoais e financeiros mapeados

- Dados cadastrais e financeiros de clientes (CPF/CNPJ, dados bancários, tokens de cartão) tratados pela plataforma de pagamentos - ver P-02.
- Histórico de transações e dados utilizados pelo motor de antifraude para análise de risco e perfilamento - ver P-06.
- Logs de acesso e de transações que possam conter identificadores associados a pessoas naturais - ver P-03.
- Dados de RH e folha de pagamento de colaboradores, tratados por sistemas administrativos de TI e, quando aplicável, por operadores externos.

C.3 Direitos dos titulares e canal de atendimento

A Organização disponibiliza canal formal (e-mail dedicado e/ou formulário) para que os titulares exerçam os direitos previstos no art. 18 da LGPD, incluindo confirmação da existência de tratamento, acesso, correção, anonimização, bloqueio, eliminação, portabilidade e revogação do consentimento, quando aplicável. As solicitações são encaminhadas ao DPO, que coordena a resposta no prazo legal, com apoio das áreas envolvidas (atendimento, antifraude, TI, jurídico).

C.4 Base legal predominante

Para dados de clientes, a base legal predominante é a execução de contrato (prestação do serviço de pagamento) e o cumprimento de obrigação legal/regulatória do setor financeiro (art. 7º, II e V, da LGPD). Para o motor de antifraude, aplica-se também o legítimo interesse



(art. 7º, IX) e a prevenção à fraude (art. 11, II, "g"), sempre precedidos de avaliação de impacto (RIPD) e de medidas de transparência junto aos clientes.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27001: Tecnologia da informação — Técnicas de segurança — Sistemas de gestão de segurança da informação — Requisitos. Versão corrigida 2023. Rio de Janeiro: ABNT, 2022.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27002: Tecnologia da informação — Segurança da informação, cibersegurança e proteção à privacidade — Controles de segurança da informação. Rio de Janeiro: ABNT, 2022.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27005: Segurança da informação, cibersegurança e proteção à privacidade — Orientação para gestão de riscos de segurança da informação. Rio de Janeiro: ABNT, 2023.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27557: Segurança da informação, cibersegurança e proteção à privacidade — Orientação para gestão de riscos de privacidade organizacional. Rio de Janeiro: ABNT, 2023.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27701: Técnicas de segurança — Extensão da ABNT NBR ISO/IEC 27001 e ABNT NBR ISO/IEC 27002 para gestão da privacidade da informação — Requisitos e diretrizes. Rio de Janeiro: ABNT, 2026.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO 31000: Gestão de riscos — Diretrizes. Rio de Janeiro: ABNT, 2018.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018.

BRASIL. Decreto-Lei nº 5.452, de 1º de maio de 1943. Consolidação das Leis do Trabalho (CLT), art. 482. Diário Oficial da União, Rio de Janeiro, 9 ago. 1943.